SECURITY INCIDENT RESPONSE PROCESS

SOP-012 | Standard Operating Procedure | Issued under POL-012

Document ID: SOP-012
Version: 1.0 — DRAFT
Parent Policy: POL-012 — Incident Response Policy
Classification: Confidential
Owner: Information Security
Co-Owner: CIO
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	Security Incident Response Process
Document ID	SOP-012
Version	1.0 — DRAFT
Document Classification	Confidential — contains IRT procedures, evidence handling, and regulatory notification workflows. Restricted to IRT members and senior leadership.
Parent Policy	POL-012 — Incident Response Policy
Related Documents	POL-003, POL-005, POL-006, POL-007, POL-009, POL-010, POL-011, POL-013, POL-014, POL-015, SOP-003, SOP-006, SOP-007, SOP-009, SOP-011, SOP-015, EXC-001
Owner	CISO
Co-Owner	CIO
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]

IMPORTANT: The GDPR 72-hour notification clock and HIPAA breach notification obligations begin at the moment a potential breach is logged by Information Security — not when it is confirmed. Under-reporting or delayed logging to manage notification timelines is a regulatory violation.

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for review

1. Purpose

This SOP defines the end-to-end security incident response lifecycle at [Company Name] — from detection through triage, containment, eradication, recovery, and post-incident review. It operationalises POL-012 by establishing specific procedures, timelines, IRT composition, evidence handling requirements, regulatory notification workflows, and GxP-specific incident handling obligations.

Three objectives must be balanced simultaneously: contain the incident, preserve evidence (forensic integrity for legal and regulatory purposes), and restore service. Evidence preservation runs in parallel with containment — it does not wait for containment to be complete. Service restoration follows evidence preservation and containment — not before.

2. Scope

This SOP applies to all security incidents at [Company Name] — events involving actual or suspected unauthorised access, data breach, malware, ransomware, insider threat, GxP data integrity compromise, account compromise, or audit trail tampering, across all systems regardless of tier.

Boundary with SOP-015: an incident that begins as an operational outage and is identified as having a security cause transitions to this SOP. Both processes may run in parallel during the transition. The Incident Commander determines the transition point and notifies CISO.

3. Incident Response Team (IRT)

IRT Role	Member	Incidents Triggered
Incident Commander (IC)	CISO (P1/P2) or Information Security Manager (P3/P4)	All incidents. IC holds overall command and accountability.
Technical Lead	Information Security Manager or senior security engineer	All incidents. Owns technical investigation workstream.
IT Response	Data Custodian (IT)	All incidents involving systems. Executes containment and recovery actions.
GxP Lead	Compliance / QA Director	Any incident involving a GxP-flagged system or GxP data, regardless of severity.
Privacy Lead	DPO	Any incident involving personal data (GDPR) or PHI (HIPAA).

IRT Role	Member	Incidents Triggered
Legal Counsel	General Counsel or external legal	P1/P2 incidents, regulatory notification decisions, law enforcement referrals.
Communications	Comms Lead	P1/P2 incidents with external notification or media risk.
BC/DR Commander	CIO	P1 incidents where BC/DR activation is required or projected.
Finance	Finance Controller	P1/P2 incidents affecting SOX ITGC systems.

IRT contact details and escalation order (primary, secondary, tertiary) are maintained in the IRT Contact List — a separate controlled document accessible via the out-of-band communications channel defined in the enterprise DR Run-Book (SOP-011).

4. Severity Classification

Severity	Criteria	IC Response	IRT Assembly	Regulatory Clock
P1 — Critical	Ransomware on Tier 1/GxP; confirmed exfiltration of personal data >1,000 subjects or any Special Category data; audit trail tampering confirmed on GxP; Tier 1 rendered unavailable; APT confirmed; privileged account compromise on Tier 1/GxP.	15 minutes	Full IRT within 30 minutes	GDPR 72-hr. HIPAA 60-day. GxP authority assessment within 24hr.
P2 — High	Confirmed unauthorised access to Tier 1/Tier 2; personal data breach <1,000 subjects, no Special Category; malware contained to non-production; suspected insider threat with data access confirmed; account compromise on Tier 2/SOX.	30 minutes	Core IRT within 1 hour	GDPR 72-hr if personal data. HIPAA assessment required.
P3 — Medium	Suspected unauthorised access under investigation; confirmed phishing credential harvest but no system access; malware detected and isolated on end-user device; policy violation with potential data exposure.	2 hours	Technical Lead + IT Response	GDPR assessment required. No automatic clock unless personal data confirmed.
P4 — Low	Failed attack (blocked); policy violation with no data exposure confirmed; security anomaly under investigation; lost/stolen device with confirmed encryption.	Next business day	Technical Lead	No notification unless investigation escalates severity.

> **NOTE:** Severity is assigned at initial triage and must be re-assessed at every stage. Incidents regularly escalate from P3 to P1 as investigation reveals the true scope. A P4 not progressed promptly is a P3 with a time advantage for the attacker.

5. Incident Response Lifecycle

Step 01	**Detection and Logging** Incident sources: SIEM alerts (POL-014 monitoring rules), SOP-015 operational incident escalation, staff report (any staff, no minimum certainty threshold), third-party notification, external notification. On detection, Information Security logs the incident in the ITSM platform immediately: — Timestamp: the time the report was received — not when investigation began. This is the legally significant clock start. — Source of detection, initial description, systems potentially affected, initial severity. The GDPR 72-hour and HIPAA notification clocks start at this timestamp.	Responsible **Information Security**
Step 02	**Triage** IC conducts triage within the response time per Section 4: 1. Confirm severity P1–P4 and assign IC 2. Identify affected systems via SIEM and system logs 3. Assess regulatory flags: personal data? GxP system? SOX? PHI? 4. Trigger IRT assembly per severity 5. Activate regulatory notification assessment — DPO if personal data; GxP Lead if GxP system 6. Establish the incident log — the single shared record for all IRT activity For P1: all steps completed within 30 minutes of IC appointment.	Responsible **IC / Information Security**
Step 03	**Containment and Evidence Preservation** These are simultaneous workstreams — not sequential. Evidence Preservation (Technical Lead — runs in parallel): — Forensic image of affected systems before any remediation — Chain of custody: who captured, when, hash value — Memory dump where volatile evidence present — Log export from SIEM for affected systems and time period — Audit trail snapshot from affected systems — immutable copy preserved — No evidence may be deleted, overwritten, or modified Containment (Data Custodian IT): — Network isolation of affected system(s) — Account suspension: all confirmed or suspected compromised accounts disabled immediately (SOP-008) — Privileged account compromise: CISO notified immediately, SOP-009 activated — Malware/ransomware: isolate before any removal attempt — GxP systems: containment actions affecting validated state require immediate Compliance/QA notification	Responsible **Technical Lead (evidence) / Data Custodian IT (containment)**
Step 04	**Regulatory Notification Assessment** Running in parallel — not a post-incident step. GDPR: DPO assesses Art.33 notifiability. Default assumption: notifiable unless DPO can confirm risk to data subjects is unlikely. 72-hour deadline from Step 1 timestamp. If deadline approaches before investigation is complete: notify with available information, supplement later. HIPAA: DPO/Privacy Lead assesses under Breach Notification Rule. Individual and HHS notification within 60 calendar days. Media notification if >500 in any state. GxP authority: Compliance/QA Director assesses within 24hr for P1/P2 GxP incidents. FDA, EMA, MHRA notification assessed against impact on GxP records and product integrity. SOX: Finance Controller notified for P1/P2	Responsible **DPO / Compliance QA / Finance Controller / Legal**

	on ITGC systems. ITGC evidence loss → external auditors notified. All notification decisions — including decisions NOT to notify — documented with DPO or Compliance/QA rationale.	
Step 05	**Investigation and Eradication** Investigation objectives: root cause, attack vector, full compromise scope, data affected. Activities: timeline reconstruction (SIEM + audit trails + forensic evidence), lateral movement scope assessment, data impact assessment, attack vector identification. Eradication (only after forensic image complete): — Remove malware/attacker tooling from all confirmed affected systems — Close the attack vector via patch, configuration change, or access revocation — Emergency Change under SOP-007 — Rotate all credentials potentially exposed — Confirm eradication: rescan, review SIEM for residual indicators of compromise	Responsible **Technical Lead / Information Security / Data Custodian IT**
Step 06	**Recovery** System must return to a confirmed-clean operational state — not just operational state. 1. Restore from a clean pre-compromise backup — do not restore from a backup within the compromise window 2. Apply all outstanding patches and hardening before returning to production 3. Confirm eradication complete before restoration 4. GxP systems: validated state restoration per SOP-011 Section 6 Step 4 — Compliance/QA Director GxP Restart Authorisation mandatory 5. SOX: Finance Controller confirms ITGC controls intact before financial operations resume 6. Enhanced monitoring: SIEM elevated for minimum 30 days post-recovery 7. All recovery actions are Emergency Changes under SOP-007	Responsible **Data Custodian IT / Compliance QA (GxP) / Finance Controller (SOX)**
Step 07	**Post-Incident Review (PIR)** Mandatory for all P1/P2. Recommended for P3 with systemic implications. Within 10 business days of incident close. Mandatory PIR sections: incident timeline, root cause, attack vector, data impact (final), detection assessment (how long after compromise?), regulatory notification summary, control effectiveness (what worked, what failed, what was missing), lessons learned, CAPA actions with named owners and target dates. PIR outputs feed: IS Risk Register (SOP-010), SOP-007 hardening changes, SOP-006 CAPA (GxP systems), ISSG quarterly report. PIR report approved by CISO. P1 incidents: retained 7 years per POL-002.	Responsible **CISO / IC / IRT**

6. Incident Type Playbooks

The following playbooks supplement — not replace — the core lifecycle in Section 5.

6.1 Ransomware

#	Action	Owner
1	Isolate all affected systems from the network immediately — before any other action. Do not attempt decryption or removal before isolation.	Data Custodian IT / CISO instruction
2	Invoke BC/DR (SOP-011) immediately — ransomware on any Tier 1 system is automatic BC/DR activation.	CIO on CISO notification
3	Assume all credentials from affected systems are compromised. Rotate credentials across all systems the affected accounts could access.	Data Custodian IT / SOP-009
4	Assess backup integrity: confirm backups pre-date infection and have not been encrypted or deleted. Many ransomware variants target backups first.	Data Custodian IT
5	DPO assesses data exfiltration risk — many ransomware operators exfiltrate before encrypting. Treat as potential personal data breach. GDPR clock runs.	DPO
6	Do not pay ransom without Legal and CISO approval. If considered: Legal assesses sanctions compliance; CISO assesses decryption key reliability.	CISO + Legal
7	Restore from confirmed clean pre-infection backups after eradication confirmed.	Data Custodian IT

6.2 GxP Data Integrity Incident

#	Action	Owner
1	GxP system quarantined immediately — no GxP activities until investigation complete and validated state confirmed.	Compliance QA on CISO notification
2	Audit trail review for affected system — SOP-003 DIRA process activated. Audit trail gaps during the incident period are ALCOA+ Completeness failures.	DIO / Compliance QA
3	Scope of GxP record compromise assessed: which records, batches, studies, regulatory consequence.	Compliance QA Director
4	Regulatory authority notification assessment within 24 hours: FDA, EMA, MHRA as applicable.	Compliance QA Director + Legal
5	Validated state restoration per SOP-011 Section 6 Step 4 and SOP-006 Section 6.3 deviation. Compliance/QA Director signs GxP Restart Authorisation.	Compliance QA Director / Validation Lead
6	VMF deviation record raised per SOP-006. CAPA actions documented.	Compliance QA / Validation Lead

6.3 Privileged Account Compromise

#	Action	Owner
1	Disable compromised account immediately — SOP-008 leaver suspension. Do not wait to confirm.	Data Custodian IT on CISO instruction
2	SOP-009 privileged account compromise procedure activated. All systems accessible by the compromised account treated as potentially affected.	CISO / SOP-009
3	PAM session recordings for compromised account reviewed immediately — scope of actions during compromise assessed.	Information Security / Technical Lead
4	Credential rotation across all systems the compromised account could access.	Data Custodian IT / SOP-009
5	For GxP systems accessed by compromised account: validated state assessment required even with no direct evidence of GxP record modification. The access itself is a deviation.	Compliance QA / SOP-006
6	Audit trail review for all GxP systems accessed during the compromise window per SOP-003 and SOP-014.	DIO / Compliance QA

7. Related Documents

Document ID	Title	Relationship
POL-012	Incident Response Policy	Parent policy — this SOP operationalises POL-012
POL-003	Data Integrity Policy	GxP data integrity incident handling in playbook 6.2; audit trail tampering is a P1 incident
POL-006	CSV Policy	GxP recovery requires validated state restoration per SOP-006; VMF deviation record for any GxP system involved
POL-007	Change Management Policy	All containment and recovery actions are Emergency Changes under SOP-007
POL-009	PAM Policy	Privileged account compromise playbook 6.3 activates SOP-009; all privileged sessions reviewed
POL-010	IS Risk Policy	PIR root cause generates IS Risk Register entries via SOP-010 within 5 business days of incident close
POL-011	BC/DR Policy	P1 incidents trigger BC/DR via SOP-011; dual workstream: CIO commands recovery, CISO commands investigation

Document ID	Title	Relationship
POL-013	Third Party Policy	Vendor-sourced incidents trigger SOP-013 vendor incident response; GDPR clock runs from [Company Name] awareness
POL-014	Audit Trail Policy	Audit trail preservation is a mandatory evidence step; gaps assessed per SOP-003 and SOP-014
SOP-003	Data Integrity Process	DIRA process activated for GxP data integrity incidents
SOP-006	Computer System Validation Process	GxP validated state restoration per SOP-006 Sections 6.3 and 6.4
SOP-007	Change Management Process	Emergency change for all containment and recovery actions
SOP-009	PAM Process	Privileged account compromise procedure activated in parallel with this SOP
SOP-011	BC/DR Process	BC/DR activation at P1; dual workstream coordination
SOP-015	ITSM Process	Operational incidents transition to this SOP on confirmed security cause
RACI-001	Roles, Responsibilities and Authorities	Accountability for incident response governance

— End of Document —

SOP-012 v1.0 DRAFT | [Company Name] | CONFIDENTIAL

10. NIS2 Article 23 — Significant Incident Reporting

This section establishes the process for reporting significant incidents to the national CSIRT and national competent authority (NCA) under NIS2 Directive Article 23. It operates in addition to — and independently of — the GDPR notification obligations in Section 6 and the GxP/FDA/EMA obligations in Section 7. The authority, trigger, timeline, and content requirements differ across all three frameworks. A single incident may trigger obligations under all simultaneously.
Warning: NIS2 Art. 23 personal liability attaches to management body members. If a significant incident is not reported within the 24-hour early warning window, the CISO must immediately notify the Board Chair and General Counsel. Failure to notify is a direct enforcement trigger.

10.1 Significant Incident Definition

A significant incident under NIS2 Art. 23 is one that: (a) causes or is capable of causing severe operational disruption to services; (b) causes significant financial loss; or (c) causes considerable material or immaterial damage to other persons. These criteria are independent — any one is sufficient. They are NOT limited to incidents involving personal data. A ransomware attack disrupting GxP manufacturing with no personal data exposure is a NIS2 significant

incident. Upon confirmation of any P1 or P2 incident, the Incident Manager shall immediately evaluate the following triggers:
Trigger 1 — Operational disruption: Severe disruption to services (any Tier 1 or GxP system unavailability exceeding 4 hours; any disruption affecting patient safety, drug supply, or regulated operations).
Trigger 2 — Financial impact: Estimated financial impact exceeds [Company Name threshold — to be set by CFO and Legal, suggested: 0.1% of annual turnover].
Trigger 3 — Third-party harm: Actual or potential material harm to customers, patients, partners, or third parties (including unauthorised access to customer/patient data, supply chain compromise, or product quality/safety impairment).
Trigger 4 — Malicious act: Evidence or reasonable suspicion of an unlawful or malicious cause (ransomware, data exfiltration, coordinated attack, nation-state actor). Must be stated in the early warning if confirmed.
Trigger 5 — Cross-border: Incident affects [Company Name] operations or customers in more than one EU member state. The NCA may coordinate notification to other member state authorities. Must be assessed and flagged in the early warning.
Note: When in doubt, treat the incident as NIS2-significant and file the early warning. Early warnings can be supplemented; a missed 24-hour deadline cannot be corrected.

10.2 Three-Stage Reporting Process

All three stages run from the moment the incident is logged in the Incident Tracking System (Step 1 of this SOP). The clock does not pause during investigation. Contact details for the national CSIRT and NCA are maintained in GOV-001 Section 6 (REF-001).

Stage 1: Early Warning — Within 24 Hours of Awareness

Submitted to: National CSIRT (or NCA). See GOV-001/REF-001 for current contacts and portal URL.
Authorised by: CISO. If unavailable: CIO. If both unavailable: CEO or General Counsel.
Required content: (a) Nature of incident — what happened, systems affected, services impacted; (b) whether caused by unlawful or malicious act (yes / no / under investigation); (c) whether cross-border implications exist (yes / no / under investigation).
The early warning does not require a complete investigation. Best available information at 24 hours is sufficient and compliant. Submitting with incomplete information and later supplementing is explicitly compliant under NIS2. Failing to submit within 24 hours is not.

Stage 2: Incident Notification — Within 72 Hours of Awareness

Submitted to: National CSIRT or NCA (same authority as Stage 1). This is concurrent with the GDPR 72-hour window but to a different authority. Both must be filed if personal data is involved.
Authorised by: CISO with General Counsel sign-off. If time critical: CISO only, with General Counsel notified immediately after submission.
Required content: (a) Initial assessment of severity, affected systems, estimated scope of impact; (b) indicators of compromise if available; (c) whether incident is ongoing; (d) updated malicious-act determination; (e) updated cross-border assessment; (f) preliminary mitigation measures taken.

Stage 3: Final Report — Within One Month of Awareness

Deadline: 30 calendar days from incident awareness. If the incident is still ongoing at 30 days: submit a progress report at day 30 and a final report within one month of resolution.
Authorised by: CISO with CEO and General Counsel sign-off.
Required content: (a) Detailed incident description; (b) type of threat or root cause; (c) applied and ongoing mitigation measures; (d) final cross-border impact assessment; (e) volume and types of affected parties; (f) technical details relevant to the national CSIRT's situational awareness function.

10.3 Notification Coordination and Board Notification

A single P1 incident may trigger NIS2, GDPR, HIPAA, and FDA/EMA obligations simultaneously. The CISO maintains a Notification Tracker in the Incident Record capturing: each obligation, relevant deadline, submission timestamp, and authority reference number. The Tracker is part of the formal incident record and must be retained for 5 years.
Any NIS2-significant incident must be notified to the Board Chair within 2 hours of significance assessment. The CISO provides a brief written summary (email sufficient): incident type, NIS2 significance basis, 24-hour early warning deadline. The full management body receives the Stage 2 notification summary within 24 hours of Stage 2 submission.
Reminder — parallel obligations: GDPR 72-hour notification goes to the data protection supervisory authority (ICO in UK, lead SA in EU). NIS2 72-hour notification goes to the national CSIRT or NCA. These are different authorities and separate submissions. Both must be filed if a P1 incident involves personal data.